

The Marriott International Data Breach

1. Introduction

The 2018 Marriott International data breach is one of the most significant cybersecurity failures in the hospitality industry. Affecting approximately 500 million guests, the breach exposed names, addresses, passport numbers, and encrypted credit card data. This incident occurred within the systems of Starwood Hotels, a brand that Marriott had acquired in 2016, revealing systemic cybersecurity weaknesses not just in Marriott's operations but in its approach to mergers and acquisitions.

The breach impacted consumers and set off a regulatory firestorm, including a £99 million fine from the UK's Information Commissioner's Office (ICO) under GDPR. As businesses increasingly rely on digital infrastructure, the Marriott case serves as a critical lesson on the need for cybersecurity to be deeply embedded in M&A due diligence and enterprise risk management practices.

2. Background Information

Before its acquisition by Marriott, Starwood Hotels had been the victim of a sophisticated cyberattack dating back to 2014. However, Marriott did not detect this long-term breach until 2018—two years after the acquisition—suggesting a severe lack of technical auditing during the merger process. The attackers maintained persistent access by exploiting vulnerabilities in Starwood's legacy IT infrastructure, systems that Marriott operated post-acquisition without significant upgrades or full integration.

This persistent threat actor could exfiltrate massive amounts of customer data undetected, capitalizing on Marriott's failure to implement adequate detection mechanisms. Despite being a leader in global hospitality, Marriott had no comprehensive process to assess or remediate cybersecurity risks in the acquired Starwood systems, which ultimately led to this breach.

3. Problem Statement

The central issue was the lack of cybersecurity due diligence during the merger and Marriott's failure to implement foundational cybersecurity practices post-acquisition. This oversight allowed a pre-existing breach in Starwood's systems to persist and escalate. Moreover, Marriott's delayed detection and reporting of the breach violated several GDPR requirements, including the obligation to notify authorities within 72 hours.

This case illustrates how the absence of a structured cybersecurity framework—particularly in the context of M&A—can lead to widespread legal, financial, and reputational damage. In short, Marriott underestimated the risks inherited through acquisition and did not apply industry-standard frameworks like NIST or ISO/IEC 27001 to assess and protect its expanded digital environment.

4. Analysis

The Marriott data breach reveals serious loopholes in the company's technical deployment and internal cybersecurity management. Examining the breach with the assistance of cybersecurity standards, one can utilize existing frameworks such as the NIST Cybersecurity Framework (CSF) and ISO/IEC 27001 for a structured analysis. The five core functions of the NIST CSF—Identify, Protect, Detect, Respond, and Recover—indicate glaring failures on Marriott's part. Interestingly, the "Identify" function, which includes identifying the organization's systems, assets, data, and associated risk, was poorly managed while integrating the acquisition process of Starwood. Marriott failed to thoroughly map or assess Starwood's IT assets and legacy systems, leaving a blind spot where the attackers went undetected for nearly four years. Moreover, the "Detect" function, which requires timely detection of cybersecurity events, was lacking or non-existent. The persistent presence of unauthorized users on the Starwood reservation system indicates a lack of advanced threat detection methods, such as Security Information and Event Management (SIEM) solutions or anomaly-based intrusion detection systems (IDS).

In ISO/IEC 27001, Marriott's approach also broke down in key control areas, such as risk assessment (Clause 6.1.2), information security objectives (Clause 6.2), and monitoring and reviewing controls (Clause 9.1). The company did not have a continuous, proactive information security management system (ISMS) that would have helped to reduce inherited risks during the M&A process. Moreover, controls in Annex A—A.8 (asset management) and A.15 (supplier relationships)—were not applied or insufficiently applied during the integration of Starwood's infrastructure.

From a regulatory point of view, Marriott breached the General Data Protection Regulation (GDPR), Article 32, which mandates reasonable technical and organizational measures to maintain security proportionate to the risk. Marriott also breached Article 33, which mandates notification of data breaches to the supervisory authorities within 72 hours. The delay in detection and reporting breaches significantly impacted customer trust and put the company at risk of regulatory action, including a proposed fine of £99 million by the UK Information Commissioner's Office (ICO).

Organizationally, the breach highlights several systemic failures. First, the lack of due diligence during the acquisition phase reflects a dangerous reliance on inherited systems without conducting independent verification. Organizational silos—where departments operate in isolation—likely prevented effective communication between Marriott's IT, legal, and compliance teams during and after the Starwood acquisition. Furthermore, legacy systems, often unsupported and challenging to secure, compounded the technical debt Marriott unknowingly inherited. Finally, there appears to have been overconfidence in third-party IT outsourcing, as Starwood had entrusted much of its operations to Accenture, leading Marriott to assume compliance without independent validation.

This case illustrates how cybersecurity is not merely a technical function but a strategic imperative that must be tightly integrated into enterprise risk management, particularly during high-risk events like mergers and acquisitions. The lack of real-time monitoring, poor asset visibility, absence of third-party risk assessments, and underdeveloped incident response plans allowed the threat to persist undetected for years—ultimately compromising the personal data of up to 500 million individuals. It serves as a cautionary tale for all global enterprises.

5. Proposed Solution

Organizations engaging in mergers and acquisitions (M&A) must embed cybersecurity as a core strategic priority throughout the deal lifecycle to prevent incidents similar to the Marriott data breach. One of the most critical measures is to mandate comprehensive pre-merger cybersecurity audits. These audits must include deep assessments of the target company's network architecture, endpoint security, data protection mechanisms, and historical breach activity. As with Starwood's compromised environment, any signs of lingering malware, vulnerabilities, or unresolved incidents must be investigated and remediated before integration. Following the acquisition, a post-merger cybersecurity remediation plan should be enforced, encompassing network segmentation, system hardening, credential resets, and re-evaluation of inherited software and vendor access rights.

Risk assessments should be standardized across all business units to ensure a consistent approach and align with internationally recognized frameworks such as ISO/IEC 27001. This includes

incorporating Annex A controls related to risk treatment (A.6.1.2), supply chain information security (A.15), and asset management (A.8). Additionally, organizations with legacy systems—which are particularly vulnerable—must prioritize modernization or security isolation of such infrastructure during integration.

Security Information and Event Management (SIEM) systems must be implemented from a technology standpoint. SIEM systems provide real-time monitoring of threats, issue alerts and facilitate forensic analysis by gathering information from organizational networks. Aside from this, there must be an established full-fledged Vendor Risk Management (VRM) program to determine third-party access and compliance with security standards across the broader enterprise. Moreover, the organization's incident response procedures must be harmonized with the NIST Cybersecurity Framework (CSF), thus ensuring consistent action in identification, protection, detection, response, and recovery.

Finally, data governance prioritization via minimization and encryption practices must be followed. Businesses must practice data minimization by regularly checking and deleting out-of-date customer data that is no longer required for operational or regulatory purposes. Data that is retained—i.e., sensitive identifiers like passport and credit card numbers—must be protected through encryption at rest and in transit using strong algorithms and secure key management practices. These practices reduce the impact of a potential breach and optimize compliance with laws like the GDPR and CCPA. These preventive measures create a multi-layered defense-in-depth approach to help mitigate cybersecurity issues in future mergers and acquisitions.

6. Results

Following the breach, Marriott initiated a comprehensive overhaul of its cybersecurity posture. This included enhanced endpoint detection, stronger encryption policies, third-party risk assessments, and global incident response training. While these actions were largely reactive, they brought Marriott's cybersecurity practices closer to industry standards and regulatory expectations.

The breach also influenced broader corporate practices. Many firms began incorporating cyber risk into the deal lifecycle, ensuring cybersecurity is assessed during pre-acquisition planning rather than as an afterthought. As a result, this case contributed to the industry-wide shift toward cybersecurity-integrated M&A strategies, marking a turning point in digital risk management.

Outside of Marriott, the event catalyzed change within the wider corporate and cybersecurity ecosystem. Companies across various industries started to see cybersecurity as an essential part of M&A consideration, not an afterthought following the deal. The event underscored the extent

to which inherited cyber risk delivers long-term liability, regulatory penalties, and reputational harm. As a result, companies began incorporating cyber risk analysis at the start of the deal process, frequently bringing in specialist cyber firms as part of due diligence. This change was a paradigm shift in digital risk management, integrating cybersecurity into strategic decision-making processes.

The Marriott case has since been used in academic, legal, and regulatory literature as a reference point moment that revolutionized cyber risk management in M&A transactions. It shaped policy guideline revisions from advisory bodies, such as mandatory breach disclosure timelines, increased due diligence requirements, and forward-looking incident planning. The breach was an eye-opener for multinational corporations, highlighting that cybersecurity needs to evolve in sync with business strategy to adequately safeguard digital and human capital.

7. Conclusion

The Marriott case exemplifies how cybersecurity gaps can undermine even the most prominent global brands. A failure to integrate cybersecurity into M&A planning, assess inherited systems, and apply structured frameworks led to a multi-year breach that compromised millions. It is a cautionary tale that cybersecurity must be treated as a core business function, particularly in high-stakes corporate activities like mergers and acquisitions.

Organizations must embrace a proactive cybersecurity posture built on recognized standards like NIST CSF, GDPR, and ISO/IEC 27001. They can only mitigate risks, protect consumer data, and build trust in an increasingly interconnected world.

8. References

- [1] M. H. Bhuyan, D. K. Bhattacharyya, and J. K. Kalita, “Network anomaly detection: Methods, systems and tools,” *IEEE Commun. Surveys Tuts.*, vol. 16, no. 1, pp. 303–336, 2014. [Online]. Available: <https://doi.org/10.1109/SURV.2013.052213.00046>
- [2] P. García-Teodoro, J. Díaz-Verdejo, G. Maciá-Fernández, and E. Vázquez, “Anomaly-based network intrusion detection: Techniques, systems and challenges,” *Comput. Secur.*, vol. 28, no. 1–2, pp. 18–28, 2009. [Online]. Available: <https://doi.org/10.1016/j.cose.2008.08.003>
- [3] G. Kim, S. Lee, and S. Kim, “A novel hybrid intrusion detection method integrating anomaly detection with misuse detection,” *Expert Syst. Appl.*, vol. 41, no. 4, pp. 1690–1700, 2014. [Online]. Available: <https://doi.org/10.1016/j.eswa.2013.08.066>

- [4] H. J. Liao, C. H. R. Lin, Y. C. Lin, and K. Y. Tung, "Intrusion detection system: A comprehensive review," *J. Netw. Comput. Appl.*, vol. 36, no. 1, pp. 16–24, 2013. [Online]. Available: <https://doi.org/10.1016/j.jnca.2012.09.004>
- [5] A. Shiravi, H. Shiravi, M. Tavallaee, and A. A. Ghorbani, "Toward developing a systematic approach to generate benchmark datasets for intrusion detection," *Comput. Secur.*, vol. 31, no. 3, pp. 357–374, 2012. [Online]. Available: <https://doi.org/10.1016/j.cose.2011.12.012>
- [6] N. Shone, T. N. Ngoc, V. D. Phai, and Q. Shi, "A deep learning approach to network intrusion detection," *IEEE Trans. Emerg. Topics Comput. Intell.*, vol. 2, no. 1, pp. 41–50, 2018. [Online]. Available: <https://doi.org/10.1109/TETCI.2017.2772792>
- [7] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in *Proc. IEEE Symp. Secur. Privacy*, Oakland, CA, USA, 2010, pp. 305–316. [Online]. Available: <https://doi.org/10.1109/SP.2010.25>
- [8] Y. Xia, X. Wang, X. Zhang, and S. Sun, "A fault-tolerant ensemble model for intelligent intrusion detection in complex data streams," *IEEE Access*, vol. 6, pp. 48305–48315, 2018. [Online]. Available: <https://doi.org/10.1109/ACCESS.2018.2867395>
- [9] J. Zhang and M. Zulkernine, "Anomaly based network intrusion detection with unsupervised outlier detection," in *Proc. IEEE Int. Conf. Commun. (ICC)*, Istanbul, Turkey, 2006, vol. 5, pp. 2388–2393. [Online]. Available: <https://doi.org/10.1109/ICC.2006.255098>
- [10] R. Zuech, T. M. Khoshgoftaar, and R. Wald, "Intrusion detection and big heterogeneous data: A survey," *J. Big Data*, vol. 2, no. 1, p. 3, 2015. [Online]. Available: <https://doi.org/10.1186/s40537-015-0013-4>